5651 Sayılı Kanun Kapsamında IP Loglarının Tutulması ve İmzalanması

İnternet erişimi sağlayan kurumlar (şirketler, oteller, kafeler, okullar gibi toplu kullanım sağlayıcılar) 5651 sayılı Kanun ve ilgili yönetmelik gereği, hangi cihaza hangi IP'nin ne zaman verildiğini kayıt altına almak ve bu kayıtları değiştirilemeyecek biçimde imzalayıp belirli bir süre saklamak zorundadır. Yönetmelik güncellenebildiği için saklama süresi ve teknik şartlar için BTK'nın güncel mevzuat sayfasına bakmak gerekir. İncelenen sürümde kayıtların günlük tutulması ve bir yıl saklanması öngörülüyordu. Önceki sürümlerde zorunlu tutulan "kurumca sağlanan yazılımı kullanma" ifadesi yönetmelikten çıkarılmıştır. Bugün birçok ürün (özellikle güvenlik duvarları) bu işi kendi yazılımıyla yapar ve piyasada çok sayıda imzalama çözümü vardır.

Bir senaryo düşünelim: Polis ya da jandarma, Cumhuriyet Savcılığı'ndan gelen gizli bir yazıyla kuruma gelir ve "şu tarihte ve saatte şu IP'den şu erişim yapıldı, kim yaptı?" diye sorar. Dışarıdan görünen IP, kurumun dış IP'sidir. Savcılık önce internet servis sağlayıcıya sorar, o da bu IP'yi o tarihte hangi abonenin kullandığını bildirir, hatta adresine kadar verir. Böylece kapı kuruma gelir. İç IP'ler internete çıkarken görünmez, yalnızca kurumun kendi cihazlarında izlenebilir.

Kurumdan beklenen, erişimi hangi cihazın yaptığını gösterebilmektir. Cihaz bulunduktan sonra o cihazı kimin kullandığı, kamera kayıtları ve benzeri araştırmalar kolluğun işidir. Yönetici açısından görev, IP ile cihazı doğru eşleştirmektir.

Bunun için tek bir log yetmez:

- **DHCP logu** hangi IP'nin hangi MAC adresine, hangi tarih ve saatte verildiğini gösterir, ancak cihazın nereye eriştiğini tutmaz.
- **Güvenlik duvarı ve router logları** dış erişimleri kaydeder. İstemciler ağdan buradan çıktığı için "şu saatte şu iç IP şu siteye erişti" bilgisi buradan alınır.
- **DNS logu** son çare olabilir, ancak önbellek nedeniyle her erişim kayda düşmez. İstemci aynı ismi daha önce çözdüyse DNS'e tekrar sormaz.

Doğru sıra şöyledir: Önce güvenlik duvarı loglarından siteye hangi iç IP'nin eriştiği bulunur, ardından DHCP loguna bakılarak o saatte bu IP'nin hangi MAC adresine verildiği tespit edilir.

MAC Adresi ve Cihaz Eşleştirme

MAC adresleri 2. katmanda çalışır. Paket başka bir ağa geçtiğinde yeni bir çerçeve oluşur ve kaynak MAC olarak router'ın adresi görünür. Bu yüzden internetteki karşı taraf istemcinin MAC adresini görmez.

MAC adresini bir kişiye bağlamak için cihazların kişilere zimmetlenmesi ve envanter tutulması gerekir. MAC adresi yazılımla değiştirilebilir, ancak fabrikada donanıma tanımlanan adres sabittir. İlk yarısı üreticiyi gösterir, bu yüzden bir MAC adresini "vendor lookup" sitelerinde aratarak markasını (örneğin bir Samsung telefon) öğrenmek mümkündür. İkinci yarı üreticinin atadığı cihaza özel kısımdır.

Ek bilgi: Üretici kısmına OUI (Organizationally Unique Identifier) denir ve adresin ilk 24 biti (3 bayt) bunu oluşturur. Modern telefonlar Wi-Fi'da gizlilik için rastgele MAC adresi kullanabilir. Bu nedenle MAC'ten cihaza ulaşmak her zaman mümkün olmayabilir.

Eşleştirmenin Zayıf Halkaları ve Çözümleri

- **Statik IP kullanan cihazlar:** DHCP'den IP almadıkları için DHCP loguna düşmezler. Duvardaki bir prize kablo takıp ağa girebilen birinin izini sürmek zorlaşır. Çözüm, 802.1X gibi port tabanlı kimlik doğrulama yöntemleriyle ağa herkesin girmesini engellemektir.
- **Misafir Wi-Fi:** Her bağlananın peşinden koşmak mümkün değildir. En temiz çözüm captive portal kurmaktır. Kişi Wi-Fi'a ya da kabloya bağlandığında karşısına TC kimlik numarası doğrulamalı bir form çıkar. Sistem bilgileri nüfus ve vatandaşlık kayıtlarıyla sorgular, doğruysa interneti açar. Böylece IP ve MAC bilgisi doğrudan bir kimlikle eşleşir.